MILLORNET

Informe de Auditoría de Seguridad

Hardening, Análisis de Logs y Escaneo de Vulnerabilidades

Campo	Valor
Empresa	Millornet — Ciberseguridad y Pentesting
Fecha de auditoría	10 de Marzo de 2026
Auditor	ikervp
Herramientas utilizadas	Lynis 3.0.9, Logwatch 7.7, Fail2ban
Sistemas auditados	millornet-router, millornet-server
Clasificación	Confidencial — Uso interno

1. Resumen Ejecutivo

La presente auditoría de seguridad ha sido realizada sobre la infraestructura de Millornet con el objetivo de evaluar el nivel de hardening de los sistemas, identificar vulnerabilidades y aplicar medidas correctivas.

Se han auditado dos máquinas críticas: el router perimetral (millornet-router) y el servidor principal (millornet-server), utilizando las herramientas Lynis para evaluación de hardening, Logwatch para análisis de logs del sistema, y Fail2ban para protección ante ataques de fuerza bruta.

▸ Resultados Globales

Máquina	Puntuación Inicial	Puntuación Final	Mejora	Estado
millornet-router	62/100	71/100	+9 puntos	✅ Mejorado
millornet-server	59/100	69/100	+10 puntos	✅ Mejorado

Ambos sistemas han experimentado una mejora significativa tras la aplicación de las medidas correctivas. El nivel de hardening resultante es adecuado para un entorno de laboratorio educativo y base sólida para continuar con el despliegue del laboratorio de pentesting.

2. Metodología

La auditoría se ha realizado siguiendo un proceso estructurado en tres fases:

Fase 1 — Análisis de Logs con Logwatch

Logwatch es una herramienta de análisis de logs que procesa los registros del sistema y genera un informe consolidado. Se ha instalado en ambas máquinas y ejecutado con nivel de detalle medio para obtener un resumen del estado del sistema.

```
$ sudo apt install logwatch -y
$ sudo logwatch --detail Med --range today --format text --output stdout
```

El análisis cubre los siguientes aspectos: actividad de usuarios, conexiones SSH, uso de sudo, cambios en paquetes, errores del kernel y espacio en disco.

Fase 2 — Protección con Fail2ban

Fail2ban monitoriza los logs del sistema y bloquea automáticamente las IPs que realizan demasiados intentos fallidos de autenticación. Se ha configurado en ambas máquinas con los siguientes parámetros:

Parámetro	Valor	Descripción
bantime	7200 segundos	Tiempo de bloqueo (2 horas)
findtime	600 segundos	Ventana de tiempo para contar intentos
maxretry	3 intentos	Máximo de fallos antes de bloquear

Fase 3 — Hardening con Lynis

Lynis es una herramienta de auditoría de seguridad para sistemas Unix/Linux. Realiza más de 200 comprobaciones de seguridad y genera un índice de hardening entre 0 y 100. Se ha ejecutado en ambas máquinas antes y después de aplicar las medidas correctivas para medir el impacto.

```
$ sudo apt install lynis -y
$ sudo lynis audit system
$ sudo grep 'hardening_index' /var/log/lynis-report.dat
```

3. Auditoría — millornet-router

Dato	Valor
Hostname	millornet-router
IP principal	10.10.10.1 (red empresa)
IP WAN	192.168.1.39 (puente)
Sistema operativo	Ubuntu Server 24.04 LTS
Kernel	6.8.0-101-generic
Rol	Router, DNS, DHCP, Firewall, VPN, ntopng

3.1 Análisis de Logs — Logwatch

El análisis de logs del router no ha revelado actividad maliciosa. Los hallazgos más relevantes son:

✅ [OK] Sin intentos de intrusión externos

No se han detectado ataques de fuerza bruta ni accesos no autorizados por SSH desde internet.

✅ [OK] WireGuard VPN activo

Handshake establecido correctamente con cliente externo. Transferencia de datos bidireccional confirmada.

ℹ️ [INFO] Errores gráficos vmwgfx

Errores del driver gráfico de VirtualBox. No afectan al funcionamiento del sistema al ser un servidor sin interfaz gráfica.

✔ **Acción: Pueden ignorarse en entorno de virtualización.**

ℹ️ [INFO] Postfix sin configurar

Logwatch instaló Postfix como dependencia pero no está configurado. No afecta al funcionamiento.

✔ **Acción: No requerido en este entorno.**

Actividad de usuarios registrada

Usuario	Acción	Veces	Observación
ikervp	Login SSH	1	Desde 192.168.1.33 (portátil VPN)
ikervp	Sudo apt	1	Instalación de paquetes
ikervp	Sudo nano	1	Edición de configuración
ikervp	Sudo logwatch	2	Ejecución de auditoría
root (cron)	Tareas programadas	3	Normal, tareas del sistema

Estado del disco

Partición	Tamaño	Usado	Libre	Uso%	Estado
/dev/mapper/ubuntu-vg	12G	4.8G	5.9G	45%	✅ Correcto
/dev/sda2 (/boot)	2.0G	100M	1.7G	6%	✅ Correcto

▸ 3.2 Análisis Lynis — Puntuación Inicial: 62/100

Las principales vulnerabilidades y sugerencias detectadas por Lynis en el router antes del hardening:

⚠️ **[ADVERTENCIA] Paquetes vulnerables (PKGS-7392)**
Se detectaron uno o más paquetes del sistema con vulnerabilidades conocidas.
✔ **Acción: sudo apt update && sudo apt upgrade -y**

⚠️ **[ADVERTENCIA] AllowTcpForwarding habilitado (SSH-7408)**
El reenvío TCP por SSH estaba habilitado, lo que puede ser usado para tunelizar tráfico no autorizado.
✔ **Acción: AllowTcpForwarding no en /etc/ssh/sshd_config**

ℹ️ **[INFO] ClientAliveCountMax demasiado alto (SSH-7408)**
El valor por defecto de 3 permite más reintentos de keepalive de los necesarios.
✔ **Acción: ClientAliveCountMax 2 en /etc/ssh/sshd_config**

ℹ️ **[INFO] Política de contraseñas no configurada (AUTH-9286)**
No había configurados máximos ni mínimos de días para las contraseñas.
✔ **Acción: PASS_MAX_DAYS 90, PASS_MIN_DAYS 1, PASS_WARN_AGE 7**

ℹ️ **[INFO] Protocolos de red innecesarios (NETW-3200)**
Los protocolos dccp, sctp, rds y tipc estaban disponibles sin ser necesarios.
✔ **Acción: Blacklist en /etc/modprobe.d/blacklist.conf**

ℹ️ **[INFO] UMASK poco restrictivo (AUTH-9328)**
El UMASK por defecto era 022, permitiendo que archivos nuevos sean legibles por todos.
✔ **Acción: UMASK 027 en /etc/login.defs**

▸ 3.3 Medidas Correctivas Aplicadas

Medida	Comando/Archivo	Estado
Actualización de paquetes	apt update && apt upgrade -y	✅ Aplicado
SSH: AllowTcpForwarding no	/etc/ssh/sshd_config	✅ Aplicado
SSH: ClientAliveCountMax 2	/etc/ssh/sshd_config	✅ Aplicado
SSH: PermitRootLogin no	/etc/ssh/sshd_config	✅ Aplicado
SSH: MaxAuthTries 3	/etc/ssh/sshd_config	✅ Aplicado
PASS_MAX_DAYS 90	/etc/login.defs	✅ Aplicado

Medida	Comando/Archivo	Estado
PASS_MIN_DAYS 1	/etc/login.defs	✅ Aplicado
PASS_WARN_AGE 7	/etc/login.defs	✅ Aplicado
UMASK 027	/etc/login.defs	✅ Aplicado
Blacklist dccp/sctp/rds/tipc	/etc/modprobe.d/blacklist.conf	✅ Aplicado
Instalación libpam-tmpdir	apt install libpam-tmpdir	✅ Aplicado
Instalación debsums	apt install debsums	✅ Aplicado
Instalación apt-show-versions	apt install apt-show-versions	✅ Aplicado
Instalación Fail2ban	apt install fail2ban	✅ Aplicado

3.4 Puntuación Final: 71/100 (+9 puntos)

Puntuación inicial: 62/100 (62%)
Puntuación final: 71/100 (71%)
Mejora obtenida: +9 puntos (+14.5%)

4. Auditoría — millornet-server

Dato	Valor
Hostname	millornet-server
IP principal	10.10.10.10 (red empresa)
IP Host-Only	192.168.56.102
Sistema operativo	Ubuntu Server 24.04 LTS
Kernel	6.8.0-101-generic
Rol	Docker Compose, Portainer, Grafana, Prometheus, Duplicati, Traefik

4.1 Análisis de Logs — Logwatch

El análisis de logs del servidor ha revelado los siguientes hallazgos:

🔴 **[CRÍTICO] Disco al 87% de capacidad**

El volumen principal /dev/mapper/ubuntu-vg-ubuntu-lv tiene solo 1.3GB libres de 9.8GB. Los overlays de Docker contribuyen significativamente al uso.

✔ **Acción: docker system prune -a para liberar imágenes y contenedores no utilizados.**

⚠️ **[ADVERTENCIA] Login fallido en tty1 (ikervp)**

Se registró un intento fallido de login en la consola local. Probablemente error tipográfico del administrador.

✔ **Acción: Revisar si se repite. Si es recurrente, investigar acceso físico.**

✅ **[OK] Contenedores Docker activos**

Se detectaron 7 interfaces veth activas correspondientes a los 7 contenedores del stack Docker Compose.

✅ **[OK] SSH activo y controlado**

Conexión SSH registrada desde 192.168.56.1 (red host-only). Sin intentos no autorizados.

Actividad de usuarios registrada

Usuario	Acción	Veces	Observación
ikervp	Login SSH	1	Desde 192.168.56.1 (host-only)
ikervp	Login tty1 FALLIDO	1	Error de contraseña en consola local
ikervp	Login tty1 exitoso	1	Acceso correcto posterior
ikervp	Sudo apt	1	Instalación de paquetes
ikervp	Sudo nano	1	Edición de configuración
ikervp	Sudo logwatch	1	Ejecución de auditoría

Estado del disco

Partición	Tamaño	Usado	Libre	Uso%	Estado
/dev/mapper/ubuntu-vg	9.8G	8.0G	1.3G	87%	⚠️ CRÍTICO
/dev/sda2 (/boot)	1.8G	100M	1.6G	7%	✅ Correcto
Docker overlays (x7)	9.8G	8.0G	1.3G	87%	⚠️ Compartido

ACCIÓN RECOMENDADA: Ejecutar docker system prune -a periódicamente y considerar ampliar el disco virtual a 20GB.

▸ 4.2 Análisis Lynis — Puntuación Inicial: 59/100

Las principales vulnerabilidades y sugerencias detectadas por Lynis en el servidor antes del hardening:

⚠️ **[ADVERTENCIA] Paquetes vulnerables (PKGS-7392)**
Uno o más paquetes del sistema tenían vulnerabilidades conocidas.
✔ **Acción: sudo apt update && sudo apt upgrade -y**

⚠️ **[ADVERTENCIA] AllowTcpForwarding habilitado (SSH-7408)**
Misma vulnerabilidad que en el router. El reenvío TCP por SSH estaba habilitado.
✔ **Acción: AllowTcpForwarding no en /etc/ssh/sshd_config**

ℹ️ **[INFO] Sin módulo PAM para fortaleza de contraseñas (AUTH-9262)**
No había ningún módulo PAM instalado para validar la complejidad de contraseñas.
✔ **Acción: Instalar pam_cracklib o pam_passwdqc**

ℹ️ **[INFO] Política de contraseñas no configurada (AUTH-9286)**
Sin límites de caducidad de contraseñas configurados.
✔ **Acción: PASS_MAX_DAYS 90, PASS_MIN_DAYS 1 en /etc/login.defs**

ℹ️ **[INFO] Protocolos de red innecesarios (NETW-3200)**
Protocolos dccp, sctp, rds y tipc disponibles sin necesidad.
✔ **Acción: Blacklist en /etc/modprobe.d/blacklist.conf**

ℹ️ **[INFO] Particiones sin separar (FILE-6310)**
/home, /tmp y /var en la misma partición raíz.
✔ **Acción: Requeriría reinstalación. No aplicable en este entorno.**

▸ 4.3 Medidas Correctivas Aplicadas

Medida	Comando/Archivo	Estado
Actualización de paquetes	apt update && apt upgrade -y	✅ Aplicado
SSH: AllowTcpForwarding no	/etc/ssh/sshd_config	✅ Aplicado
SSH: ClientAliveCountMax 2	/etc/ssh/sshd_config	✅ Aplicado

Medida	Comando/Archivo	Estado
SSH: PermitRootLogin no	/etc/ssh/sshd_config	✅ Aplicado
SSH: MaxAuthTries 3	/etc/ssh/sshd_config	✅ Aplicado
PASS_MAX_DAYS 90	/etc/login.defs	✅ Aplicado
PASS_MIN_DAYS 1	/etc/login.defs	✅ Aplicado
PASS_WARN_AGE 7	/etc/login.defs	✅ Aplicado
UMASK 027	/etc/login.defs	✅ Aplicado
Blacklist dccp/sctp/rds/tipc	/etc/modprobe.d/blacklist.conf	✅ Aplicado
Instalación libpam-tmpdir	apt install libpam-tmpdir	✅ Aplicado
Instalación debsums	apt install debsums	✅ Aplicado
Instalación apt-show-versions	apt install apt-show-versions	✅ Aplicado
Instalación Fail2ban + jail SSH	apt install fail2ban	✅ Aplicado

▸ 4.4 Puntuación Final: 69/100 (+10 puntos)

Puntuación inicial: 59/100 (59%)

Puntuación final: 69/100 (69%)

Mejora obtenida: +10 puntos (+16.9%)

5. Configuración Fail2ban

Fail2ban se ha instalado y configurado en ambas máquinas para proteger el servicio SSH contra ataques de fuerza bruta.

5.1 Configuración aplicada

```
$ cat /etc/fail2ban/jail.local
[DEFAULT]
bantime  = 7200
findtime  = 600
maxretry = 3

[sshd]
enabled = true
port    = ssh
maxretry = 3
bantime = 7200
findtime = 600
```

5.2 Estado del servicio

```
$ sudo fail2ban-client status
Status
|- Number of jail:      1
`- Jail list:   sshd
```

5.3 Funcionamiento

Escenario	Comportamiento
3 intentos fallidos en 10 minutos	IP bloqueada automáticamente durante 2 horas
IP bloqueada intenta conectar	Conexión rechazada sin respuesta
Ver IPs baneadas	sudo fail2ban-client status sshd
Desbanear IP manualmente	sudo fail2ban-client unban IP

6. Comparativa y Conclusiones

6.1 Evolución del Hardening Index

Máquina	Antes	Después	Mejora	Nivel
millornet-router	62/100	71/100	+9 pts (+14.5%)	Bueno
millornet-server	59/100	69/100	+10 pts (+16.9%)	Bueno
Media	60.5/100	70/100	+9.5 pts (+15.7%)	Bueno

6.2 Vulnerabilidades resueltas

Vulnerabilidad	Severidad	Router	Servidor
Paquetes vulnerables	Alta	✅ Resuelto	✅ Resuelto
AllowTcpForwarding SSH	Media	✅ Resuelto	✅ Resuelto
Sin política de contraseñas	Media	✅ Resuelto	✅ Resuelto
Protocolos red innecesarios	Baja	✅ Resuelto	✅ Resuelto
UMASK poco restrictivo	Baja	✅ Resuelto	✅ Resuelto
Sin Fail2ban	Alta	Ya tenía	✅ Resuelto
Disco al 87%	Alta	N/A	⚠️ Pendiente limpiar
Particiones separadas	Baja	⚠️ No aplicable	⚠️ No aplicable

6.3 Puntos pendientes de mejora

- Ampliar disco del servidor de 10GB a 20GB para evitar problemas de espacio con Docker.
- Ejecutar docker system prune -a periódicamente para limpiar imágenes no utilizadas.
- Instalar pam_pwquality para reforzar la complejidad de contraseñas.
- Configurar auditoría con auditd para registro detallado de comandos ejecutados.
- Implementar Wazuh como SIEM para correlación de eventos entre todas las máquinas.
- Configurar SSL/TLS en todos los servicios web (Portainer, Grafana, Traefik).
- Activar 2FA en Portainer y Grafana.

6.4 Conclusión

La infraestructura de Millornet ha alcanzado un nivel de hardening adecuado para un entorno de laboratorio de ciberseguridad. Las medidas aplicadas cubren los vectores de ataque más comunes: autenticación SSH, política de contraseñas, protocolos de red innecesarios y protección ante fuerza bruta.

El índice medio de hardening de 70/100 sitúa la infraestructura en un nivel considerado 'Bueno' por los estándares de Lynis, superando la media de sistemas sin hardening (típicamente entre 40-55/100).

Como próximos pasos, se recomienda implementar un SIEM con Wazuh para tener visibilidad completa de los eventos de seguridad en tiempo real, y continuar con el despliegue del laboratorio de máquinas vulnerables para prácticas de pentesting.